PRAVEEN V 241901082

Exercise 9
Web Application Vulnerability Scanning

AIM

To identify vulnerabilities in an authorized web application (OWASP Juice Shop) using OWASP ZAP, perform a vulnerability scan and classify the findings by severity, and compare automated scan results with manual browser inspection.

PROCEDURE

a) Performing a Vulnerability Scan and Classifying Findings by Severity

1. Start the OWASP Juice Shop application and note its URL (e.g., http://localhost:3000).
2. Open OWASP ZAP and set the browser proxy to route through ZAP (127.0.0.1:8080).
3. Enter the target URL in ZAP and allow it to load the site through the proxy so the request is added to the Sites tab.
4. Right-click the target site in ZAP and select Attack → Active Scan, then start the scan.
5. Wait for the scan to complete and open the Alerts tab to view all vulnerabilities found.
6. Note each vulnerability along with its risk rating as classified by ZAP: High, Medium, Low or Informational.
7. Record the vulnerability name, affected URL/parameter and severity in the observation table.

b) Comparing Automated Scan Results with Manual Browser Inspection

1. Manually browse the application and inspect pages, forms and responses using the browser's Developer Tools (Inspect/Network tab).
2. Check manually for common issues such as missing security headers, exposed comments in page source, weak input validation and visible error messages.
3. Compare the vulnerabilities found manually with those reported by the ZAP automated scan.
4. Note any vulnerabilities found only by the scanner, only manually, or by both methods.

OBSERVATION TABLE

S.No	Vulnerability	Affected URL/Parameter	Severity	Found By
1	SQL Injection	/rest/user/login	High	ZAP Scan + Manual
2	Cross-Site Scripting (XSS)	/search?q=	High	ZAP Scan
3	Missing Anti-CSRF Tokens	/rest/user/login	Medium	ZAP Scan
4	X-Content-Type-Options Header Missing	Site-wide	Low	ZAP Scan
5	Sensitive	/#/login	Informational	Manual

S.No	Vulnerability	Affected URL/Parameter	Severity	Found By
	Comments in Source Code			Inspection
6	Verbose Error Messages	/rest/products/search	Medium	Manual Inspection

OUTPUT

ZAP Alerts summary:

High (2) : SQL Injection, Cross-Site Scripting (XSS)

Medium (2) : Missing Anti-CSRF Tokens, Verbose Error Messages

Low (1) : X-Content-Type-Options Header Missing

Informational(1): Sensitive Comments in Source Code

Manual inspection finding (page source):

<!-- TODO: remove debug endpoint /rest/user/login before production -->

Comparison result:

Found by both : SQL Injection

Found only by ZAP scan : XSS, Missing Anti-CSRF Tokens, Header Missing

Found only manually : Sensitive Comments, Verbose Error Messages

RESULT

Thus, vulnerability scanning on the authorized web application was successfully performed using OWASP ZAP. The findings were classified by severity, and the automated scan results were compared with manual browser inspection, identifying vulnerabilities detected by each method.